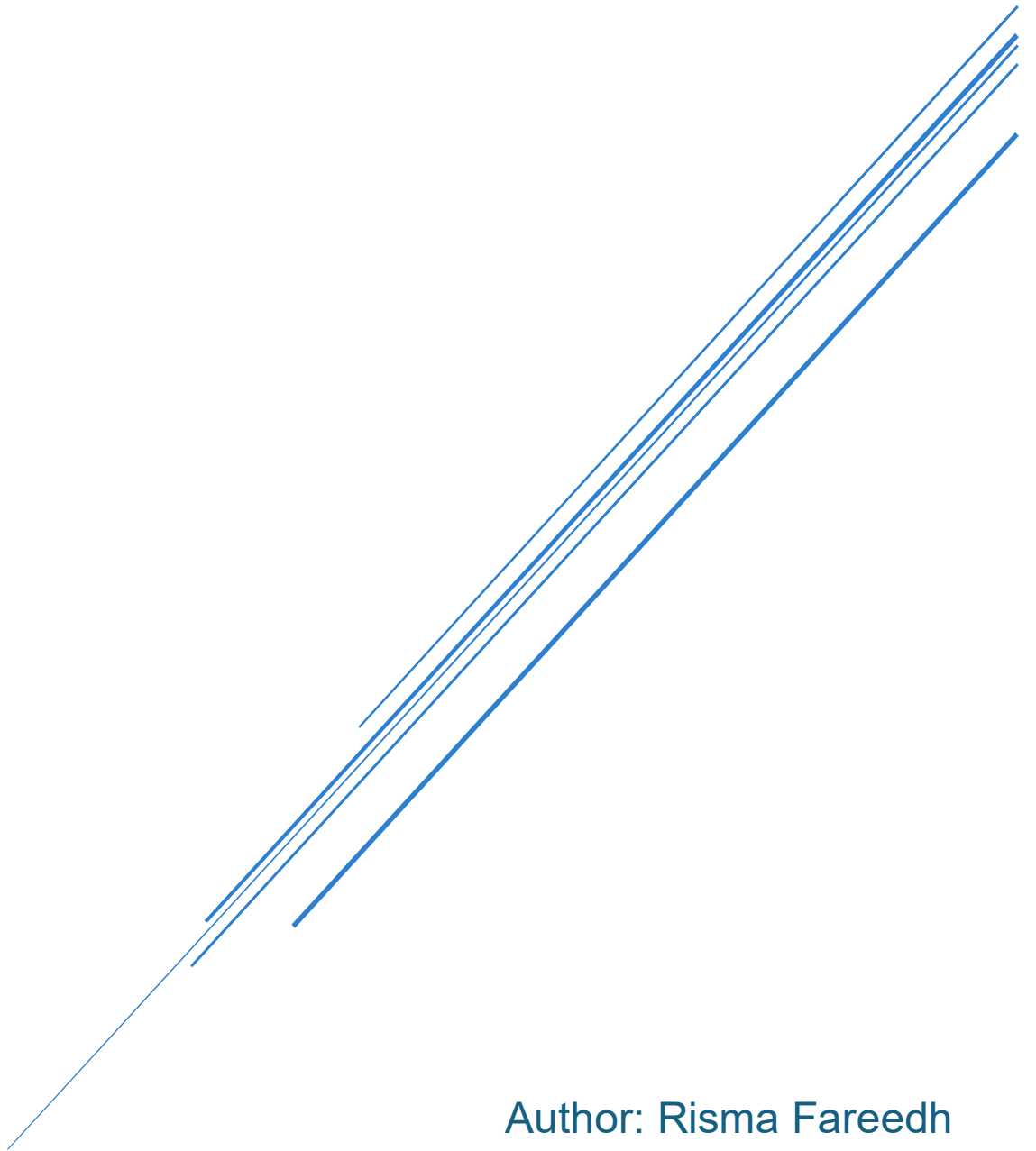


CURRENT PRACTICES

Of Banking Industry



Author: Risma Fareedh
AION Campus
Governance, Risk, Compliance (GRC)

Industry: Banking

Bank Name: Q Bank

4. Context of the Organization

Sub-Section	Current Practices
4.1 Understanding the organization and its context	SWOT analysis conducted to identify internal/external factors, but not formally documented.
4.2 Understanding the needs and expectations of interested parties	Regulatory requirements identified; customers and vendors partially considered informally.
4.3 Determining the scope of the ISMS	Scope defined for Core Banking, ATMs, Internet and Mobile Banking.
4.4 Information security management system	ISMS manual exists, covers some processes, but not updated to ISO 27001:2022.

5. Leadership

Sub-Section	Current Practices
5.1 Leadership and commitment	Board approved ISMS project; quarterly reviews planned.
5.2 Policy	Draft Information Security Policy exists but not formally signed by top management.
5.3 Organizational roles, responsibilities and authorities	RACI matrix created for IT and business units; roles clearly defined.

6. Planning

Sub-Section	Current Practices
6.1.1 Actions to address risks and opportunities	Initial risk register created; some risks identified.
6.1.2 Information security risk assessment	Ad-hoc risk reviews performed; no formal methodology.
6.1.3 Information security risk treatment	No formal Statement of Applicability or treatment plan yet.
6.2 Information security objectives and planning	Some objectives defined (e.g., reduce phishing), but not enterprise-wide or fully SMART.

7. Support

Sub-Section	Current Practices
7.1 Resources	Budget allocated for SIEM, DLP, and core security tools.
7.2 Competence	Some staff trained on security; training coverage incomplete.
7.3 Awareness	No structured awareness program; security knowledge relies on individual initiative.
7.4 Communication	Incident communication exists informally; no formal ISMS communication plan.
7.5.1 Documented information – General	Some documents maintained, but version control inconsistent.
7.5.2 Creating and updating	Document templates exist; review/approval cycles informal.
7.5.3 Control of documented information	Document distribution and retention processes exist but not fully defined.

8. Operation

Sub-Section	Current Practices
8.1 Operational planning and control	Operational processes exist (IT and banking operations) but monitoring is limited.
8.2 Information security risk assessment	Risk assessments performed occasionally but not formalized.
8.3 Information security risk treatment	Patch management and encryption implemented; other risk treatments not fully documented.

9. Performance Evaluation

Sub-Section	Current Practices
9.1 Monitoring, measurement, analysis and evaluation	SIEM implemented; KPIs defined partially for certain systems only.
9.2.1 Internal audit – General	No internal audits conducted yet.
9.2.2 Internal audit programme	No audit program exists; auditing ad-hoc.
9.3.1 Management review – General	Reviews planned but not executed.
9.3.2 Management review inputs	No structured inputs; only informal discussions on ISMS.
9.3.3 Management review results	Not applicable yet; outputs not documented.